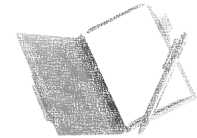




FAKULTÄT ANGEWANDTE INFORMATIK

Bachelor „Cyber Security“ –

CY-B-26 Penetration Testing



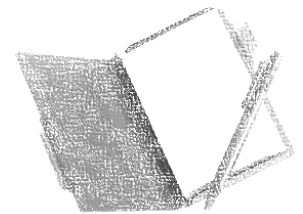
Agenda – Penetration Testing

- | | |
|--|--------------------------|
| ▪ 01: Einführung | |
| ▪ 02: (Recap &) Grundlagen (Linux, Windows) I | <i>Fundamentals</i> |
| ▪ 03: (Recap &) Grundlagen (Scripting, Network, AD) II | |
| ▪ 04: Arten, Methodik, Phasen eines Penetrationstests | |
| ▪ 05: Pre-/Post-Engagement (Berichtswesen) | <i>Pre-Exploitation</i> |
| ▪ 06: Passive/Aktive Informationsbeschaffung | |
| ▪ 07: Einführung in die Exploiting-Thematik | |
| ▪ 08: Exploit-Entwicklung in Python | <i>Exploitation</i> |
| ▪ 09: Metasploit Framework / Meterpreter | |
| ▪ 10: Post-Information Gathering | |
| ▪ 11: File Transfer & Privilege Escalation | <i>Post-Exploitation</i> |
| ▪ 12: Netzwerk-Enumeration & Ausbreitung | |
| ▪ 13: Praktikumsleistung | |
| ▪ 14: Prüfungsvorbereitung | <i>Examination</i> |
| ▪ 15: Prüfungsleistung | |

Agenda – Penetration Testing

- 04: Arten, Methodik, Phasen eines Penetrationstests
- 05: Pre-/Post-Engagement (Berichtswesen) *Pre-Exploitation*
- 06: Passive/Aktive Informationsbeschaffung

- Pre-Engagement
 - Scoping
 - Rules of Engagement
- „(Post-)Engagement“
 - Documentation
 - Reporting
- Zusammenfassung & Transferfragen
- *Workshop*





Pre-Engagement – Scoping



Scoping - Meeting

- Ablauf bis zum „eigentlichen“ Penetrationstest
 - Anfrage Kunde
 - Gespräch zur **Aufwandsabschätzung** (*Rough Order of Magnitude*)
 - Angebotserstellung Dienstleister
 - Auftragserteilung Kunde
 - (eigentliches) **Scoping Meeting** (keine Diskussion über Kosten)
 - Erstellung „Rules of Engagement“
 - Bestätigung „RoE“ durch Kunde
 - „Engagement“

Scoping - Allgemein

- Sehr wichtige Komponente eines Penetrationstests und
- ... meistens übersehen, da viele Quellen mit Tools zum Gaining Access (Information Gathering) beginnen
- Vorbereitung schützt vor Scope Creep, unzufriedene Kunden und ggf. vor rechtlichen Problemen
- Ergebnis mündet in den Rules of Engagement
- Inhalte: IP Ranges, DNS, Email, Firewall/IDS/..., 3rd Parties
- Dient der Aufwandsabschätzung: Personal und Zeit

Scoping - Aufwandsabschätzung

**ggf. für Out-of-Scope
Leistungen Regieleistungen
im Angebot vermerken**

- Problematik der Aufwandsabschätzung
- Oftmals ein Fehler: Lineare Kostenannahme **<- ?!**
- Erfahrung des PenTesters -> 20% Zeit-„Padding“
- Schützt vor unerwartet auftretenden Problemen oder doch unvorhergesehenem (besprochenen) Mehraufwand
- PenTest sollte ein fixes Anfangs- und Enddatum haben
- Was, wenn man schon früher fertig ist und die 20% nicht in Anspruch nimmt? (Unethisch)

Scoping – Fragestellungen im Scoping Gespräch

- Abhängig von der Art des Penetrationstests!!!
- Beispiel: Network Penetration Test
 1. Why is the customer having the penetration test performed against their environment?
 2. Is the penetration test required for a specific compliance requirement?
 3. When does the customer want the active portions (scanning, enumeration, exploitation, etc...) of the penetration test conducted?
 1. During business hours?
 2. After business hours?
 3. On the weekends?
 4. How many total IP addresses are being tested?
 1. How many internal IP addresses, if applicable?
 2. How many external IP addresses, if applicable?
 5. Are there any devices in place that may impact the results of a penetration test such as a firewall, intrusion detection/prevention system, web application firewall, or load balancer?
 6. In the case that a system is penetrated, how should the testing team proceed?
 1. Perform a local vulnerability assessment on the compromised machine?
 2. Attempt to gain the highest privileges (root on Unix machines, SYSTEM or Administrator on Windows machines) on the compromised machine?
 3. Perform no, minimal, dictionary, or exhaustive password attacks against local password hashes obtained (for example, /etc/shadow on Unix machines)?

Quelle PTES

Scoping – Fragestellungen im Scoping Gespräch

- Abhängig von der Art des Penetrationstests!!!
 - Beispiel: Network Penetration Test
7. Does the customer provide a PenTesting-Box, should one be provided or is it necessary to execute the PenTest on site.
 8. What does the customer expect as a result from the PenTest. Only PenTest report or with a presentation via web or on site.
 9. Additional services: Social Engineering, Phishing, Wireless, Red Team Assessment, Active Directory, Passwort Audit, Stolen Device Check, Evil Employee, etc.
- Weitere Beispiele für Web Application, Wireless, Physical, Social Engineering unter [http://www.pentest-standard.org/index.php/Pre-engagement#General Questions](http://www.pentest-standard.org/index.php/Pre-engagement#General_Questions)

Scoping – Fragestellungen im Scoping Gespräch

■ Teilnehmer des Scoping Gesprächs?!

- Geschäftsführer/Manager, IT-Leiter, Systemadministrator, Netzwerkadministrator, AD Administrator, ..., Betriebsrat(?!)
- Fragen an Manager
 1. Is the manager aware that a test is about to be performed?
 2. What is the main datum that would create the greatest risk to the organization if exposed, corrupted, or deleted?
 3. Are testing and validation procedures to verify that business applications are functioning properly in place?
 4. Will the testers have access to the Quality Assurance testing procedures from when the application was first developed?
 5. Are Disaster Recovery Procedures in place for the application data?
 6. Legal things (already covered in the first lecture) including NDA, AGB's

Scoping – Fragestellungen im Scoping Gespräch

■ Teilnehmer des Scoping Gesprächs

– Fragen an Administrator

1. Are there any systems which could be characterized as fragile? (systems with tendencies to crash, older operating systems, or which are unpatched)
2. Are there systems on the network which the client does not own, that may require additional approval to test?
3. Are Change Management procedures in place?
4. What is the mean time to repair systems outages?
5. Is any system monitoring software in place?
6. What are the most critical servers and applications?
7. Are backups tested on a regular basis?
8. When was the last time the backups were restored?

Scoping – Fragestellungen im Scoping Gespräch

- Weitere Themen des Scoping Gesprächs
 - Kommunikation während dem PenTest inkl. Frequenz der Berichterstattung
 - Notfallkontakte und Incident Reporting
 - Sichere Datenübertragung, Beispiel PW-Audit TCV

```
C:\WINDOWS\system32\cmd.exe

C:\Users\admin\Downloads\age>age-keygen -o customer_key.txt
age-keygen: warning: writing secret key to a world-readable file
Public key: age1vnmsg5g5pr4cddz9c2a5wygvr3mm4m929kty77c4pw0ng07mjczsvrh6e5

C:\Users\admin\Downloads\age>more customer_key.txt
# created: 2023-01-26T15:47:37+01:00
# public key: age1vnmsg5g5pr4cddz9c2a5wygvr3mm4m929kty77c4pw0ng07mjczsvrh6e5
AGE-SECRET-KEY-1P8SARJ93WHNQCQYQ4RXZN50F03653NFHRFA4N5UV6EJDWD5TPM9UQU565Y0

C:\Users\admin\Downloads\age>
```



```
age -o sensitive_data.jpg.age -r age1vnmsg5g5pr4cddz9c2a5wygvr3mm4m929kty77c4pw0ng07mjczsvrh6e5 sensitive_data.jpg
```

age-v1.1.1-windows-amd64

Name	Änderungsdatum	Typ	Große
customer_key.txt	26.01.2023 15:47	Textdokument	1 KB
sensitive_data.jpg	26.01.2023 15:46	JPG-Datei	50 KB
sensitive_data.jpg.age	26.01.2023 15:50	AGE-Datei	50 KB

Scoping – Fragestellungen im Scoping Gespräch

■ Beispiel Übersicht über Netze und Domains

Übersicht aller Netze / Domains (Scope)

Netzbereiche für internen Test

LEGENDE Netze im Scope, aber nur oberflächliche Tests (Scanning, non-invasive Schwachstellenscans)

	VLAN ID	Netzbereich	Erreichbarkeit	Anmerkung	Standort
Beispiel	50	192.168.25.0/24	nicht reglementiert	User VLAN	Headquarter
Beispiel	60	10.0.30.0/24	ACL inbound, nur Port 445,389,53,67	Server VLAN	Headquarter
Beispiel	110	172.16.8.0/24	nicht reglementiert	Produktion	Example-Town

Netzbereiche / Domains externer Test

	Domains / Endpunkt	Hosting	Standort	Anmerkung
Beispiel	example.domain.org	self-hosted		Max. 50 Requests / Sekunde
Beispiel	*.otherdomain.org	self-hosted		Keine Einschränkungen
Beispiel	88.148.5.156	self-hosted	Example-Town	

Prüfungsmaschine SoSe 23

- Windows
- Remote Exploit
- WinPEAS



```

#####|| Checking for Unquoted Service Paths
Fetching the list of services, this may take a while...
Unquoted Service Path found!
Name: RemoteMouseService
PathName: C:\Program Files (x86)\Remote Mouse\RemoteMouseService.exe
StartName: .\steve
StartMode: Auto
Running: Running

#####|| Creating Service Registry Permissions
This will take some time.

#####|| SCHEDULED TASKS vulnerable check

#####|| Testing access to \windows\system32\Tasks
No admin access to scheduled tasks folder.
  
```

```

←[1;36m ┌──────────┐ ←[1;32mRecent files --limit 70--←[0m
C:\Backups(05.05.2025 13:11:10)
C:\Backups\backup_script.ps1(05.05.2025 13:11:10)
  
```

```

←[1;36m ┌──────────┐ ←[1;32mScheduled Applications --Non Microsoft--←[0m
←[1;36m ┌──────────┐ ←[1;34mCheck if you can modify other users scheduled binaries ←[1;33mhttps://book.hacktricks.xyz/windows-hardening/wi
(CYB-PEN-WIN\steve) Backups: ←[0m←[1;31mpowershell.exe -ExecutionPolicy Bypass -c C:\backups\backup_script.ps1←[0m
←[0m←[1;31mPermissions file: Authenticated Users [WriteData/CreateFiles]←[0m
←[0m←[1;31mPermissions folder(DLL Hijacking): Authenticated Users [WriteData/CreateFiles]←[0m
Trigger: At 08:35 on 04.07.2023-After triggered, repeat every 00:05:00 indefinitely.
  
```

```

←[1;36m ┌──────────┐ ←[1;32mSearching executable files in non-default folders with write (equivalent) permissions (can be slow)
←[1;31m File Permissions "C:\Backups\backup_script.ps1": Authenticated Users [WriteData/CreateFiles]←[0m
←[1;31m File Permissions "C:\$Recycle.Bin\S-1-5-21-2287121386-1831611055-8947382-1001\I6IUM3F.ps1": Users [AppendData/Cr
←[1;31m File Permissions "C:\$Recycle.Bin\S-1-5-21-2287121386-1831611055-8947382-1001\I853322.ps1": Users [AppendData/Cr
←[1;31m File Permissions "C:\$Recycle.Bin\S-1-5-21-2287121386-1831611055-8947382-1001\R6IUM3F.ps1": Users [AppendData/Cr
  
```

Vielen Dank für die Aufmerksamkeit! Noch Fragen?

Kontakt

Email: michael.heigl@th-deg.de

Tel.: +49 (0) 991 3615-537

Raum: ITC2+ 1.04

<https://www.th-deg.de/protectit>

